

API First Architecture Standard

نسخه سند ۱.۰ :

وضعیت Freeze: شده برای طراحی و توسعه پروژه ERP SaaS

۱. هدف سند

این سند مجموعه قوانین و استانداردهای طراحی، توسعه و استفاده از API در پلتفرم ERP SaaS را تعریف می‌کند.

هدف اصلی این استاندارد:

- ایجاد یک قرارداد ارتباطی مشخص بین بخش‌های مختلف سیستم
- جلوگیری از وابستگی مستقیم بین ماژول‌ها
- حفظ قابلیت توسعه بلندمدت سیستم
- آماده‌سازی معماری برای رشد ماژولار و تبدیل احتمالی به معماری Microservice در آینده
- جلوگیری از پراکندگی منطق کسب‌وکار در لایه‌های مختلف سیستم

اصل ۱: قرارداد رسمی ارتباط سیستم است

تمام ارتباطات بین بخش‌های مختلف سیستم باید از طریق API انجام شود.

هیچ بخش خارجی یا داخلی سیستم اجازه ندارد برای دریافت یا تغییر اطلاعات، مستقیماً به دیتابیس یا ساختار داخلی یک ماژول دیگر دسترسی داشته باشد.

API تنها مرجع رسمی تعامل بین اجزای سیستم است.

اصل ۲: تفکیک API Layer از Business Logic الزامی است

لایه API فقط مسئول موارد زیر است:

- دریافت درخواست
- اعتبارسنجی اولیه
- مدیریت ارتباط با مصرف‌کننده
- انتقال درخواست به لایه کسب‌وکار

لایه API نباید شامل:

- قوانین کسب و کار
- محاسبات تخصصی
- فرآیندهای ERP
- تصمیمات سازمانی

باشد.

منطق اصلی سیستم باید در لایه Business Logic قرار گیرد.

اصل ۳: عدم اتصال مستقیم Client به Database

هیچ Client یا برنامه مصرف کننده ای اجازه اتصال مستقیم به Database را ندارد.

تمام عملیات:

- ایجاد اطلاعات
- خواندن اطلاعات
- ویرایش اطلاعات
- حذف اطلاعات

باید از طریق API انجام شود.

اصل ۴: هر ماژول باید API مستقل داشته باشد

هر ماژول ERP باید Interface مشخص و مستقل خود را ارائه دهد.

ماژول ها نباید جداول داخلی یا ساختار دیتابیس خود را به عنوان روش ارتباطی در اختیار سایر بخش ها قرار دهند.

ارتباط صحیح:

Client / Module → API → Module Service

ارتباط ممنوع:

Module → Database Tables → Module

اصل ۵: تمام API ها باید Version داشته باشند

تمام API های سیستم باید از ابتدا دارای نسخه باشند.

اهداف نسخه‌بندی:

- جلوگیری از شکستن مصرف‌کنندگان موجود
 - امکان توسعه تدریجی
 - حفظ Backward Compatibility
 - امکان تغییرات کنترل‌شده در آینده
- هیچ API بدون Version مجاز نیست.

اصل ۶: تغییرات API نباید باعث اختلال در سیستم موجود شود

در صورت تغییر ساختار API:

- نسخه قبلی باید تا زمان مناسب حفظ شود.
- تغییرات ناسازگار نباید روی نسخه فعال اعمال شود.
- فرآیند مهاجرت باید کنترل شده باشد.

اصل ۷: منطق کسب‌وکار فقط در Backend معتبر است

هیچ مصرف‌کننده‌ای مانند Frontend یا سیستم خارجی نباید منطق کسب‌وکار را پیاده‌سازی کند.

تمام قوانین مربوط به:

- محاسبات
- اعتبارسنجی
- محدودیت‌ها
- فرآیندها
- تصمیمات سازمانی

باید در Backend اجرا شوند.

اصل ۸: کنترل دسترسی فقط از Core Identity انجام می‌شود

هیچ ماژولی اجازه ایجاد سیستم Authorization مستقل ندارد.

تمام بررسی‌های مربوط به:

- User Permission

- Role

- Scope

- Tenant Access

باید توسط سیستم مرکزی Identity & Access انجام شود.

ماژول‌ها فقط نتیجه دسترسی را مصرف می‌کنند.

اصل ۹: تمام API ها باید Tenant Aware باشند

با توجه به معماری: Shared Database Multi Tenant

تمام API های عملیاتی باید Tenant جاری را مشخص و کنترل کنند.

هیچ API اجازه ندارد بدون تعیین Tenant:

- اطلاعات بخواند

- اطلاعات ایجاد کند

- اطلاعات تغییر دهد

نشست اطلاعات بین Tenant ها (Data Bleed) خط قرمز سیستم است.

اصل ۱۰: ارتباط بین ماژول‌ها باید Loose Coupled باشد

ارتباط بین ماژول‌ها نباید باعث وابستگی سخت شود.

موارد ممنوع:

- دسترسی مستقیم به جداول ماژول دیگر

- وابستگی به ساختار داخلی دیتابیس

- وابستگی به کلاس‌ها و پیاده‌سازی داخلی ماژول‌ها

روش‌های مجاز:

- API Contract

- Event Contract

- Logical Reference

اصل ۱۱: ساختار پاسخ API باید استاندارد باشد

تمام API ها باید از الگوی پاسخ یکسان استفاده کنند.

خروجی API باید شامل موارد استاندارد باشد:

- وضعیت عملیات
- داده خروجی
- پیام
- اطلاعات خطا
- کد خطا

هدف، ایجاد رفتار یکسان در تمام API های سیستم است.

اصل ۱۲: مدیریت خطا باید استاندارد باشد

خطاهای API باید:

- دارای کد مشخص باشند.
 - قابل تشخیص توسط Client باشند.
 - اطلاعات داخلی سیستم را افشا نکنند.
 - پیام مناسب برای مصرف کننده داشته باشند.
-

اصل ۱۳: تمام API ها باید مستند باشند

هر API باید دارای مستندات کامل باشد.

مستندات شامل:

- Endpoint
- Method
- ورودی ها
- خروجی ها
- خطاها

- سطح دسترسی

- نسخه API

باشد.

استاندارد مستندسازی:

OpenAPI Specification

اصل ۱۴: استاندارد نامگذاری API الزامی است

مسیرهای API باید از استاندارد مشخص پیروی کنند.

قوانین:

- استفاده از kebab-case در Route ها

- استفاده از نامهای مفهومی کسب و کار

- عدم وابستگی نام API به ساختار Database

API باید زبان Business Domain را نمایش دهد، نه ساختار جداول.

اصل ۱۵: API نباید ساختار داخلی سیستم را افشا کند

مصرفکننده API نباید از موارد زیر اطلاع داشته باشد:

- نام جداول Database

- روابط داخلی Database

- ساختار ذخیره سازی اطلاعات

- جزئیات پیاده سازی داخلی

API یک قرارداد کسب و کاری است، نه نمایش Database Schema.

اصل ۱۶: عملیات حساس باید Audit شوند

عملیات مهم سیستم باید قابلیت ثبت و پیگیری داشته باشند.

مانند:

- تغییر اطلاعات مالی

- تغییر سطح دسترسی
 - تغییر تنظیمات مهم
 - عملیات مدیریتی
-

اصل ۱۷: طراحی API باید توسعه‌پذیر باشد

API ها باید امکان اضافه شدن موارد زیر را بدون تغییرات بنیادی فراهم کنند:

- ماژول‌های جدید
 - Client های جدید
 - Integration های جدید
 - سرویس‌های آینده
-

اصل ۱۸: استفاده از Event برای ارتباطات غیرهمزمان

برای فرآیندهایی که نیاز به پاسخ فوری ندارند، استفاده از Event پیشنهاد می‌شود.

موارد مناسب:

- Notification
 - پردازش‌های سنگین
 - هماهنگی بین ماژول‌ها
 - عملیات پس‌زمینه
-

اصل ۱۹: معماری باید قابلیت استفاده از API Gateway را حفظ کند

حتی اگر در نسخه اول سیستم Backend یکپارچه باشد، طراحی باید امکان استفاده از API Gateway در آینده را حفظ کند.

اهداف:

- مدیریت ورودی‌ها
- امنیت
- Routing
- مدیریت نسخه‌ها

- کنترل دسترسی

اصل ۲۰: هیچ بخشی اجازه دور زدن API را ندارد

این قانون نهایی معماری است.

موارد زیر ممنوع هستند:

- خواندن مستقیم دیتابیس ماژول دیگر
 - تغییر مستقیم اطلاعات خارج از سرویس مربوطه
 - دور زدن قوانین Business Logic
 - ایجاد مسیر ارتباطی خارج از API
- تمام تعاملات سیستم باید از مسیرهای تعریف شده معماری انجام شود.

وضعیت Freeze

این سند با عنوان:

API First Architecture Standard Version ۱,۰

به عنوان یکی از اسناد اصلی معماری پروژه ERP SaaS ثبت می شود.

از این پس تمام طراحی ها، توسعه ها و تصمیمات فنی باید با این استاندارد تطبیق داده شوند.

این استاندارد در کنار اسناد زیر مرجع اصلی طراحی سیستم خواهد بود:

۱. ERP Module Design Principles

۲. Database Naming Convention Standard

۳. API First Architecture Standard